

# Briefing: Adopting Passwordless Authentication for Modern Enterprises

## Executive Summary

As of 2026, passwordless authentication has transitioned from an emerging best practice to a structural requirement for enterprise identity security. Traditional password-based systems and legacy multi-factor authentication (MFA)—such as SMS, OTP, and push-only notifications—no longer meet modern risk and compliance standards. This briefing outlines the critical shift toward phishing-resistant credentials, specifically FIDO2 and passkeys, and identifies the most significant vulnerability in modern deployments: insecure recovery and enrollment flows.

The core takeaway for leadership is that passwordless authentication is not merely a single login event but a continuous decision-making process that integrates device trust and adaptive risk. Successful adoption requires addressing the "hard" parts of the estate, including legacy applications and contractor access, while ensuring that recovery mechanisms are as secure as the primary authentication method to prevent the "bypass attacks" that have recently resulted in losses exceeding hundreds of millions of dollars for global enterprises.

## 1. The Market Shift: From Novelty to Structural Requirement

The authentication landscape is being reshaped by four primary forces that make passwordless adoption a necessity rather than an option.

- **Phishing Resistance as the Floor:** Stolen credentials remain the leading initial access vector for breaches. OTP, SMS, and push-only MFA are increasingly viewed as insufficient for high-risk environments.
- **Passkey Ubiquity:** Passkeys (FIDO2/WebAuthn) are now supported across all major operating systems and browsers. The barrier to adoption is no longer technical but focused on enterprise governance.
- **Zero-Trust Evolution:** Modern security frameworks demand that authentication combine strong cryptography with continuous contextual verification.
- **Regulatory Pressures:**
  - **Europe:** EIDAS-related initiatives are aligning public sector identity programs with phishing-resistant assurance levels.
  - **United States:** NIST has formalized AM2 and AM3 requirements, explicitly calling for hardware-bound, phishing-resistant authenticators.

## 2. The Baseline: FIDO2 and Passkey Governance

In the current market, support for FIDO2 and passkeys is considered a baseline capability rather than a competitive differentiator. Organizations must evaluate solutions based on how they **govern** these credentials at scale rather than their mere existence.

## Four Pillars of Passkey Governance

| Pillar                      | Description                                                                                    |
|-----------------------------|------------------------------------------------------------------------------------------------|
| <b>Identity Environment</b> | Credentials must be issued against a verified identity, not via anonymous self-service.        |
| <b>Device Binding</b>       | Credentials must be cryptographically bound to hardware-backed storage (TPM, Secure Enclave).  |
| <b>Lifecycle Management</b> | Automated provisioning and deprovisioning must occur across both managed and personal devices. |
| <b>Recovery Hardening</b>   | Secure methods must be in place for when a user loses a device or credential.                  |

### 3. The Vulnerability: Recovery and Enrollment

The most critical insight for 2026 is that "passwordless without recovery hardening is just theater." Attackers have shifted focus from cracking passwords to exploiting weak recovery flows through helpdesk impersonation.

#### The Problem of "Airbus" Recovery

Recent high-profile breaches (e.g., MGM Resorts and Marks & Spencer) involved attackers calling helpdesks to reset MFA or bypass authentication entirely. If a passwordless system allows fallback to a phishable factor—like a password, security question, or SMS—the entire security posture is compromised.

#### Recommended Recovery Patterns

To maintain a true passwordless environment, enterprises should adopt one or more of the following:

- 1 **Verified Device Rebinding:** Re-enrollment gated by possession of a previously trusted device.
- 2 **Identity Proofing-Backed Recovery:** Using government ID verification or biometric reproofing to replace knowledge-based questions.
- 3 **Policy-Controlled Helpdesk Flows:** Administrative oversight featuring audit traces, out-of-band verification, and bidirectional authentication (authenticating the helpdesk to the user and vice versa).

### 4. Continuous Authentication and Adaptive Risk

Authentication is no longer a "front door" event; it is a continuous policy enforcement moment. Leading solutions now integrate the following signals directly into the authentication decision:

- **Device Posture and Health:** Assessing whether a device is managed, has EDR active, or shows signs of compromise (e.g., "Mobile Lock" technology for unmanaged devices).
- **Contextual Risk Engines:** Evaluating IP reputation, geovelocity, and behavioral anomalies in real-time.

- **Orchestration:** The ability to design "journey orchestration" where different levels of risk trigger different responses (e.g., a login from an unregistered device triggers a biometric step-up, while a managed device on a trusted network requires only a passkey).
- **Shared Signals Framework:** An emerging standard allowing different security tools to share risk information, enabling the termination of active sessions if a user begins suspicious activity after the initial login.

## 5. Strategic Implementation and Legacy Challenges

While cloud-native and modern web applications are easily moved to passwordless, the "easy half" of the estate is often followed by difficult legacy systems.

- **The Legacy Gap:** Systems using Radius, VPN, VDI, or mainframes often lack the protocols to support FIDO2 directly.
- **The "Equivalent Security" Approach:** If FIDO2 is impossible for a specific legacy use case, enterprises should use the strongest possible alternative (e.g., time-based OTP or agent-based integrations) rather than reverting to simple passwords.
- **The Outside-In Strategy:** Practitioners recommend starting with SaaS and managed endpoints (the perimeter) and working toward the data center, rather than attempting to "boil the ocean" by converting all systems at once.

## 6. Vendor Archetypes and Selection

The market for passwordless solutions currently splits into two primary archetypes. Organizations must choose an architectural path based on their existing infrastructure.

| Archetype                    | Description                                                                                        | Trade-offs                                                                                                              |
|------------------------------|----------------------------------------------------------------------------------------------------|-------------------------------------------------------------------------------------------------------------------------|
| <b>Platform Consolidator</b> | Vendors who embed passwordless into a broader IAM suite (e.g., Microsoft, SAP-centric migrations). | Lower friction for existing users, but may have shallower assurance depth.                                              |
| <b>The Specialist</b>        | Vendors built specifically for high-assurance, device-bound authentication.                        | Deeper integration with device posture and recovery hardening; requires more integration work with existing IAM stacks. |

## 7. Actionable Recommendations for Leadership

To advance a passwordless strategy, organizations should focus on the following immediate actions:

- 1 **Audit Recovery Flows:** Map every fallback factor. If any are phishable (SMS, security questions), these are the primary vulnerabilities.
- 2 **Hardening RFPs:** When evaluating vendors, move beyond "Do you support FIDO2?" and ask:
  - How do you evaluate device health and binding across managed and personal devices?
  - What identity assurance level is targeted at enrollment?
  - Can your policy engine act on contextual signals (like geovelocity) in real-

time?

- 3 Prioritize User Experience (UX):** A successful rollout often uses a portfolio of methods (FIDO2, QR codes, and OTP) through a unified interface so the user experience remains consistent even if the underlying technology changes across different applications.